



ZAP by
Checkmarx

Reporte de MGC SEGUROS

Site: <https://mgc-autos-production.up.railway.app>

Generated on Sat, 26 Sept 2026 21:11:41

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	5
Low	3
Informational	4

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap. log file for details	2
Info	Informational	https://mgc-autos-production.up.railway.app	Percentage of responses with status code 2xx	99 %
Info	Informational	https://mgc-autos-production.up.railway.app	Percentage of responses with status code 4xx	1 %
Info	Informational	https://mgc-autos-production.up.railway.app	Percentage of endpoints with content type image /jpeg	8 %
Info	Informational	https://mgc-autos-production.up.railway.app	Percentage of endpoints with content type text /css	16 %
Info	Informational	https://mgc-autos-production.up.railway.app	Percentage of endpoints with	58 %

		production. up.railway. app	content type text /html	
Info	Informational	https://mgc- autos- production. up.railway. app	Percentage of endpoints with content type text /javascript	16 %
Info	Informational	https://mgc- autos- production. up.railway. app	Percentage of endpoints with method GET	100 %
Info	Informational	https://mgc- autos- production. up.railway. app	Count of total endpoints	12
Info	Exceeded Low	https://mgc- autos- production. up.railway. app	Percentage of slow responses	10 %

Alerts

Name	Risk Level	Number of Instances
CSP: Failure to Define Directive with No Fallback	Medium	2
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Cross-Domain Misconfiguration	Medium	Systemic
Missing Anti-clickjacking Header	Medium	Systemic
Sub Resource Integrity Attribute Missing	Medium	Systemic
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	Systemic
Strict-Transport-Security Header Not Set	Low	Systemic
X-Content-Type-Options Header Missing	Low	Systemic
Authentication Request Identified	Informational	2
Information Disclosure - Sensitive Information in URL	Informational	5
Re-examine Cache-control Directives	Informational	Systemic
User Controllable HTML Element Attribute (Potential XSS)	Informational	10

Alert Detail

Medium	CSP: Failure to Define Directive with No Fallback
Description	The Content Security Policy fails to define one of the directives that has no fallback. Missing /excluding them is the same as allowing anything.
URL	https://mgc-autos-production.up.railway.app/robots.txt

Node Name	https://mgc-autos-production.up.railway.app/robots.txt
Method	GET
Attack	
Evidence	default-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	https://mgc-autos-production.up.railway.app/sitemap.xml
Node Name	https://mgc-autos-production.up.railway.app/sitemap.xml
Method	GET
Attack	
Evidence	default-src 'none'
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://mgc-autos-production.up.railway.app
Node Name	https://mgc-autos-production.up.railway.app
Method	GET
Attack	
Evidence	
Other Info	
URL	https://mgc-autos-production.up.railway.app/
Node Name	https://mgc-autos-production.up.railway.app/
Method	GET
Attack	
Evidence	

Other Info	
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,phone,photo-back,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	
Other Info	
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&nombre=ZAP&password=ZAP
Node Name	https://mgc-autos-production.up.railway.app/ (email,nombre,password)
Method	GET
Attack	
Evidence	
Other Info	
URL	https://mgc-autos-production.up.railway.app/dashboard.html
Node Name	https://mgc-autos-production.up.railway.app/dashboard.html
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038
Medium	Cross-Domain Misconfiguration
Description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	https://mgc-autos-production.up.railway.app

Node Name	https://mgc-autos-production.up.railway.app
Method	GET
Attack	
Evidence	access-control-allow-origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://mgc-autos-production.up.railway.app/dashboard.css
Node Name	https://mgc-autos-production.up.railway.app/dashboard.css
Method	GET
Attack	
Evidence	access-control-allow-origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://mgc-autos-production.up.railway.app/robots.txt
Node Name	https://mgc-autos-production.up.railway.app/robots.txt
Method	GET
Attack	
Evidence	access-control-allow-origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://mgc-autos-production.up.railway.app/sitemap.xml
Node Name	https://mgc-autos-production.up.railway.app/sitemap.xml
Method	GET
Attack	
Evidence	access-control-allow-origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://mgc-autos-production.up.railway.app/styles.css
Node Name	https://mgc-autos-production.up.railway.app/styles.css
Method	GET

Attack	
Evidence	access-control-allow-origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	Systemic
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.
Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy 'frame-ancestors' directive or X-Frame-Options.
URL	https://mgc-autos-production.up.railway.app
Node Name	https://mgc-autos-production.up.railway.app
Method	GET
Attack	
Evidence	
Other Info	
URL	https://mgc-autos-production.up.railway.app/
Node Name	https://mgc-autos-production.up.railway.app/
Method	GET
Attack	
Evidence	
Other Info	
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9000000000&back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,nombre,password,phone,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	
Other	

Info	
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&nombre=ZAP&password=ZAP
Node Name	https://mgc-autos-production.up.railway.app/ (email,nombre,password)
Method	GET
Attack	
Evidence	
Other Info	
URL	https://mgc-autos-production.up.railway.app/dashboard.html
Node Name	https://mgc-autos-production.up.railway.app/dashboard.html
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP header them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	Sub Resource Integrity Attribute Missing
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	https://mgc-autos-production.up.railway.app
Node Name	https://mgc-autos-production.up.railway.app
Method	GET
Attack	
Evidence	<link href="https://fonts.googleapis.com/css2?family=DM+Sans:wght@400;500;600;700&family=Fraunces:opsz,wght@9..144,600&display=swap" rel="stylesheet">
Other Info	
URL	https://mgc-autos-production.up.railway.app/
Node Name	https://mgc-autos-production.up.railway.app/
Method	GET
Attack	
	<link href="https://fonts.googleapis.com/css2?family=DM+Sans:wght@400;500;600;

Evidence	700&family=Fraunces:opz,wght@9..144,600&display=swap" rel="stylesheet">
Other Info	
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,phone,photo-back,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	<link href="https://fonts.googleapis.com/css2?family=DM+Sans:wght@400;500;600;700&family=Fraunces:opz,wght@9..144,600&display=swap" rel="stylesheet">
Other Info	
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&nombbre=ZAP&password=ZAP
Node Name	https://mgc-autos-production.up.railway.app/ (email,nombbre,password)
Method	GET
Attack	
Evidence	<link href="https://fonts.googleapis.com/css2?family=DM+Sans:wght@400;500;600;700&family=Fraunces:opz,wght@9..144,600&display=swap" rel="stylesheet">
Other Info	
URL	https://mgc-autos-production.up.railway.app/dashboard.html
Node Name	https://mgc-autos-production.up.railway.app/dashboard.html
Method	GET
Attack	
Evidence	<link href="https://fonts.googleapis.com/css2?family=DM+Sans:wght@400;500;600;700&family=Fraunces:opz,wght@9..144,600&display=swap" rel="stylesheet">
Other Info	
Instances	Systemic
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003
Low	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	https://mgc-autos-production.up.railway.app
Node Name	https://mgc-autos-production.up.railway.app

Method	GET
Attack	
Evidence	x-powered-by: Express
Other Info	
URL	https://mgc-autos-production.up.railway.app/dashboard.css
Node Name	https://mgc-autos-production.up.railway.app/dashboard.css
Method	GET
Attack	
Evidence	x-powered-by: Express
Other Info	
URL	https://mgc-autos-production.up.railway.app/robots.txt
Node Name	https://mgc-autos-production.up.railway.app/robots.txt
Method	GET
Attack	
Evidence	x-powered-by: Express
Other Info	
URL	https://mgc-autos-production.up.railway.app/script.js
Node Name	https://mgc-autos-production.up.railway.app/script.js
Method	GET
Attack	
Evidence	x-powered-by: Express
Other Info	
URL	https://mgc-autos-production.up.railway.app/sitemap.xml
Node Name	https://mgc-autos-production.up.railway.app/sitemap.xml
Method	GET
Attack	
Evidence	x-powered-by: Express
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Low	Strict-Transport-Security Header Not Set
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://mgc-autos-production.up.railway.app
Node Name	https://mgc-autos-production.up.railway.app
Method	GET
Attack	
Evidence	
Other Info	
URL	https://mgc-autos-production.up.railway.app/dashboard.css
Node Name	https://mgc-autos-production.up.railway.app/dashboard.css
Method	GET
Attack	
Evidence	
Other Info	
URL	https://mgc-autos-production.up.railway.app/robots.txt
Node Name	https://mgc-autos-production.up.railway.app/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	https://mgc-autos-production.up.railway.app/script.js
Node Name	https://mgc-autos-production.up.railway.app/script.js
Method	GET
Attack	
Evidence	
Other Info	
URL	https://mgc-autos-production.up.railway.app/sitemap.xml
Node Name	https://mgc-autos-production.up.railway.app/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	

Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security-Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://mgc-autos-production.up.railway.app
Node Name	https://mgc-autos-production.up.railway.app
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://mgc-autos-production.up.railway.app/dashboard.css
Node Name	https://mgc-autos-production.up.railway.app/dashboard.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://mgc-autos-production.up.railway.app/dashboard.js
Node Name	https://mgc-autos-production.up.railway.app/dashboard.js
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://mgc-autos-production.up.railway.app/mgc.jpg

Node Name	https://mgc-autos-production.up.railway.app/mgc.jpg
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://mgc-autos-production.up.railway.app/script.js
Node Name	https://mgc-autos-production.up.railway.app/script.js
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains key=value lines which identify any relevant fields. If the request is in a context which has an Auth Method set to "Auto-Detect" then this rule will change the authentication to match the request id
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9&back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,nombre,password,phone,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	password
Other Info	userParam=email userValue=zaproxy@example.com passwordParam=password referer=https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&nombre=ZAP&password=ZAP
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&nombre=ZAP&password=ZAP
Node Name	https://mgc-autos-production.up.railway.app/ (email,nombre,password)

Method	GET
Attack	
Evidence	password
Other Info	userParam=email userValue=zaproxy@example.com passwordParam=password referer=https://production.up.railway.app
Instances	2
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Information Disclosure - Sensitive Information in URL
Description	The request appeared to contain sensitive information leaked in the URL. This can violate PCI and organizational compliance policies. You can configure the list of strings for this check to add or remove specific to your environment.
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,nombre,password,phone,photo-back,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	zaproxy@example.com
Other Info	The URL contains email address(es).
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,nombre,password,phone,photo-back,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	password
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern: password
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,phone,photo-back,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	zaproxy@example.com
Other Info	The URL contains email address(es).

URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&nombre=ZAP&r
Node Name	https://mgc-autos-production.up.railway.app/ (email,nombre,password)
Method	GET
Attack	
Evidence	zaproxy@example.com
Other Info	The URL contains email address(es).
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&nombre=ZAP&r
Node Name	https://mgc-autos-production.up.railway.app/ (email,nombre,password)
Method	GET
Attack	
Evidence	password
Other Info	The URL contains potentially sensitive information. The following string was found via the patter
Instances	5
Solution	Do not pass sensitive information in URIs.
Reference	
CWE Id	598
WASC Id	13
Plugin Id	10024

Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://mgc-autos-production.up.railway.app
Node Name	https://mgc-autos-production.up.railway.app
Method	GET
Attack	
Evidence	public, max-age=0
Other Info	
URL	https://mgc-autos-production.up.railway.app/
Node Name	https://mgc-autos-production.up.railway.app/
Method	GET
Attack	
Evidence	public, max-age=0
Other Info	
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-

	back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,phone,photo-back,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	public, max-age=0
Other Info	
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&nombre=ZAP&password=ZAP
Node Name	https://mgc-autos-production.up.railway.app/ (email,nombre,password)
Method	GET
Attack	
Evidence	public, max-age=0
Other Info	
URL	https://mgc-autos-production.up.railway.app/dashboard.html
Node Name	https://mgc-autos-production.up.railway.app/dashboard.html
Method	GET
Attack	
Evidence	public, max-age=0
Other Info	
Instances	Systemic
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015

Informational	User Controllable HTML Element Attribute (Potential XSS)
Description	This check looks at user-supplied input in query string parameters and POST data to identify what attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) for further review by a security analyst to determine exploitability.
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9&back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,nombre,password,phone,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET

Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS possible. The page at the following URL: https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950 appears to include user [input] tag [value] attribute The user input found was: line=civil The user-controlled value was: ci
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,nombre,password,phone,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS possible. The page at the following URL: https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950 appears to include user [input] tag [value] attribute The user input found was: purpose=new The user-controlled value w
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,nombre,password,phone,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS possible. The page at the following URL: https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950 appears to include user [input] tag [value] attribute The user input found was: use=personal The user-controlled value w
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,nombre,password,phone,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS possible. The page at the following URL: https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950

	txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950 appears to include user [input] tag [value] attribute The user input found was: vehicle=sedan The user-controlled value v
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,nombre,password,p photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS possible. The page at the following URL: https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&nombre=ZAP&password=ZAP&phone=9back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950 appears to include user [input] tag [min] attribute The user input found was: year=1950 The user-controlled value was: 1
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,phone,photo-back,p left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS possible. The page at the following URL: https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950 appears to include user [input] tag [value] attribute The user input found was: line=civil The user-controlled value was: ci
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,phone,photo-back,p left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS possible. The page at the following URL: https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950 appears to include user [input] tag [value] attribute The user input found was: purpose=new The user-controlled value w
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,phone,photo-back,p left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET

Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS possible. The page at the following URL: https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950 appears to include user [input] tag [value] attribute The user input found was: use=personal The user-controlled value was
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,phone,photo-back,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS possible. The page at the following URL: https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950 appears to include user [input] tag [value] attribute The user input found was: vehicle=sedan The user-controlled value was
URL	https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950
Node Name	https://mgc-autos-production.up.railway.app/ (email,line,make,model,name,phone,photo-back,photo-front,photo-left,photo-right,photo-serial,purpose,use,vehicle,vin,year)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS possible. The page at the following URL: https://mgc-autos-production.up.railway.app/?email=zaproxy%40example.com&line=civil&make=ZAP&model=ZAP&name=ZAP&phone=9999999999&photo-back=test_file.txt&photo-front=test_file.txt&photo-left=test_file.txt&photo-right=test_file.txt&photo-serial=test_file.txt&purpose=new&use=personal&vehicle=sedan&vin=ZAP&year=1950 appears to include user [input] tag [min] attribute The user input found was: year=1950 The user-controlled value was: 1
Instances	10
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
CWE Id	20
WASC Id	20
Plugin Id	10031